

PING

Koło Naukowe
Politechniki Gdańskiej



Prezentacja ma
charakter
wyłącznie
edukacyjny

“Rubber Ducky”

Wykonali

BIESZKE TOMASZ
MIECZKOWSKI ARTUR

Rubber Ducky

RubberDucky to zarówno pendrive, jak i emulacja klawiatury stworzony przez **Hak5**. Z pozoru jest to zwykły pendrive, jednak działa jako **Human Interface Device (HID)**. Oszukuje komputer, by zostało wykryte jako klawiatura i pozwalało np. na *Keystroke Injection*.

Skrypty do niego pisze się w języku *Ducky Script* i przekompilowane w formie binarnej za pomocą narzędzia **Payload Studio** umieszcza na pamięci masowej jako plik *inject.bin*. Takie działanie nazywamy *Hotplug Attack* i możliwe jest przez domyślne działanie urządzenia po podłączeniu w trybie *Plug and Play*.



Ducky Script

Po prawej stronie widoczny jest przykładowy kod w Ducky Script, którego zbiór instrukcji nazywamy *payloadem*.

REM (Remark) - dodaje komentarz do payloada, np. tytuł czy autora

DELAY - wstrzymuje działanie payloada na określony przez argument czas (w ms)

STRING - wstrzykuje naciśnięcia podanych klawiszy (a-z, 0-9, znaki interpunkcyjne i specjalne)

ENTER - specjalny klawisz, który może zostać wciśnięty (może to być chociażby *TAB*, *ESCAPE*, czy nawet *ALT F4*)



```
REM My first payload  
DELAY 3000  
STRING Hello, World!  
ENTER
```



Taki kod po prostu wklejamy do narzędzia Payload Studio i generujemy plik *inject.bin*



Ograniczenia Rubber Ducky

Różnica sprzętu

Każdy sprzęt różni się np. zainstalowanym oprogramowaniem czy układem klawiatury.

Brak feedbacku

Rubber Ducky nie wie, czy np. okno terminala faktycznie się otworzyło czy komenda została wykonana poprawnie. Musimy brać takie rzeczy pod uwagę na etapie tworzenia.

Dostęp fizyczny

Rubber Ducky wymaga podpięcia do portu USB lub USB-C, co zwiększa ryzyko wykrycia i wymaga fizycznej ingerencji. Samo wpisywanie znaków również nie jest natychmiastowe.



Działanie keyloggera

- 1** **Inicjacja:** Rubber Ducky otwiera okno terminala za pomocą `Win + R → cmd`
- 2** **Wstrzykiwanie kodu:** Rubber Ducky wpisuje kod prostego keyloggera w C linia po linii do pliku `main.c`
- 3** **Kompilacja:** Uruchomienie lokalnego kompilatora (gcc) i stworzenie pliku wykonywalnego `.exe`
- 4** **Uruchomienie:** Start keyloggera w ukrytym procesie i dodanie do harmonogramu zadań jako autostart

Nasz keylogger w sposób ciągły rejestruje wciśnięcia klawiszy zapisując je do lokalnego pliku `log.txt`, po czym cyklicznie przesyła dane na lokalny serwer (`127.0.0.1`).

Aplikacja serwerowa napisana w Pythonie odbiera te informacje i wyświetla je w interfejsie graficznym z rozdzieleniem na nazwy zaatakowanych użytkowników.





Prezentacja ma
charakter
wyłącznie
edukacyjny

Prezentacja działania keyloggera w oparciu o Rubber Ducky



Jak się bronić?

Bezpieczeństwo fizyczne

Staraj się blokować urządzenie i nie zostawiać odblokowanego komputera bez nadzoru. Można również stosować fizyczne zaślepki czy nawet programowo wyłączyć nieużywane porty w BIOS/UEFI. Brak praw administratora nie chroni przed naszym skryptem.

Systemy ERD (Endpoint Detection and Response)

Nowoczesne systemy ERD analizują zachowanie w czasie rzeczywistym i są w stanie wykryć np. nieludzką prędkość wprowadzania znaków z klawiatury czy nowy proces w tle.

Menedżery haseł / 2FA

Nawet w przypadku przechwycenia hasła przez keylogger, odpowiednio skonfigurowane 2FA ochroni nas, blokując dostęp bez fizycznego tokena czy aplikacji mobilnej.



PING

Koło Naukowe
Politechniki Gdańskiej

Źródła

docs.hak5.org/hak5-usb-rubber-ducky/
payloadstudio.hak5.org/community/